

Phishing Triage & Awareness Analysis Report

Prepared By: Muhammad Abd Ur Rehman

Role: Cybersecurity Analyst

Date: July 2026

This toolkit addresses how our organization tackles phishing threats by combing technical control gaps with typical psychological triggers. The goal is to build a practical workflow that non-expert employees can use to handle suspicious emails safely before escalating them to our security team.

PART 1: PHISHING INDICATOR & THREAT TAXONOMY MATRIX

Modern attacks rarely rely on obvious spelling errors anymore. Instead, attackers split their tactics between technical infrastructure masking and exploiting basic human behavior under pressure.

1. Visual & Domain Illusion Tactics

- **Typosquatting:** Intentionally registering misspelled variations of familiar corporate domains (such as using amaz0n.com or gooog1e.com) to slip past users who read quickly.
- **Homoglyph Attacks:** Replacing standard Latin letters with identical-looking characters from other alphabets—like Cyrillic or Greek. For example, a user might see a regular "a" that is actually a completely different character code, tricking both the eye and basic string filters.
- **Combosquatting:** Adding legitimate-sounding words like "support", "secure", or "verify" next to a trusted brand name (e.g., paypal-secure-login.com) to build false trust.

2. Cognitive Trigger Vulnerabilities

Social engineering tricks focus heavily on breaking down a user's normal caution by triggering specific emotional responses:

- **Authority:** Impersonating executives, directors, or legal teams to issue directives that employees feel uncomfortable questioning.
- **Urgency:** Setting tight, highly artificial timelines (e.g., "Action needed within 1 hour") to force hasty mistakes before formal validation can happen.
- **Fear or Greed:** Hinting at bad professional consequences like disciplinary action, or dangling financial windfalls like unannounced bonuses or gift cards.
- **Curiosity:** Using vague but highly enticing subject lines, such as internal organizational changes or leaked performance files, to bait clicks.

PART 2: NON-EXPERT RED FLAG ANALYSIS CHECKLIST

The checklist below serves as an operational reference guide for standard users to review incoming messages objectively.

Focus Area	Specific Red Flag Markers	Risk Level	Justification
Sender Line	Display name shows an internal colleague, but the actual email header reveals an outside address.	Critical	Exploits quick visual recognition to hide unauthorized senders.
Subject Context	Fake thread continuation strings like "RE:" or "FW:" attached to a topic the user has never discussed.	High	Forces an artificial sense of familiarity and continuity.
Mail Headers	Explicit failures, missing parameters, or clear mismatches across SPF, DKIM, or DMARC validation logs.	Critical	Confirms data tampering or an unverified relay source.
Interface Rules	Browser-in-the-Browser (BitB) popups where the sign-in window is trapped completely inside the web page structure.	Critical	Renders fake browser elements to steal credentials seamlessly.
Attachments	Raw file extensions using .iso, .js, .scr, or macro-enabled documents hidden inside zip files.	Critical	High risk of background script execution or malicious smuggling.
Call to Action	Urgent requests asking users to bypass established legal approvals or accounting verification steps.	High	Classic operational profile for high-value corporate fraud.

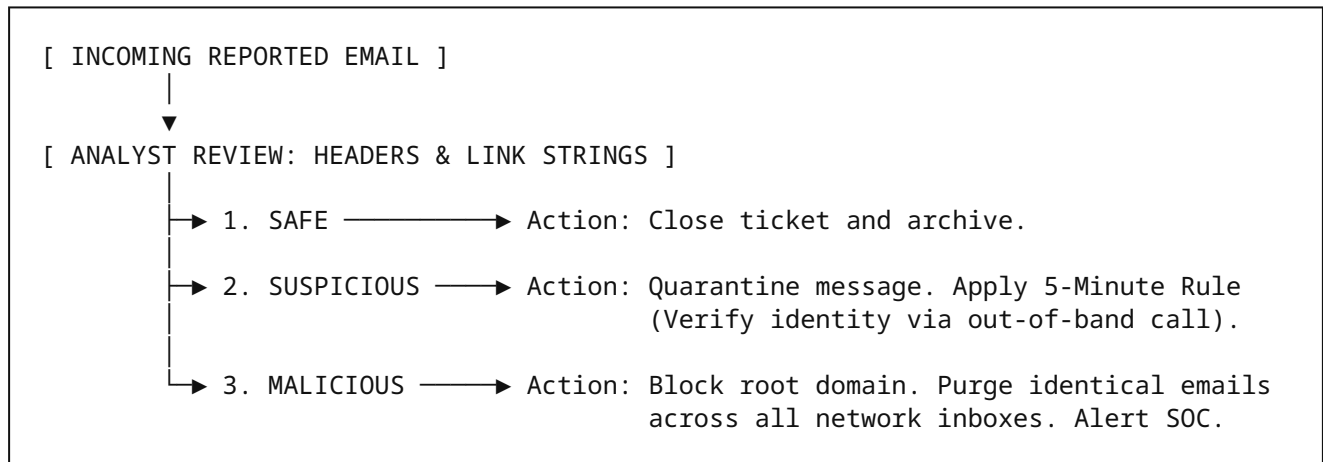
PART 3: STANDARD OPERATING PROCEDURE (SOP) FOR TRIAGE

Phase 1: Ingest & Header/URL Parsing Execution

- 1. Isolation:** View the reported email only via a secure preview pane or sandboxed terminal. Absolutely do not interact with links or open attached files directly.
- 2. Check Header Fields:** Inspect the real From: line, the Return-Path, and the sending IP address against known company infrastructure to isolate spoofed text.
- 3. Link Analysis:** Hover over link text to confirm the true destination. Read the domain string from right to left, starting from the first forward slash, to see exactly where the link lands.

Phase 2: Actionable Outcome Decision Tree

Every single reported email must follow one of these three clear administrative tracks:



PART 4: ANALYSIS OF MODERN MULTI-CHANNEL THREATS

As standard spam and network filters improve, attackers are stepping away from pure email templates toward hybrid attack flows:

1. Callback Phishing / Telephone-Directed Attack Delivery (TOAD)

Attackers send out clean, plain-text emails claiming that an expensive subscription has been renewed. These messages contain no links or files, making them completely invisible to typical email security scanners. The trap is a "customer support" phone number. When the user calls to cancel the charge, support scams trick them into setting up remote-access software or sharing login tokens.

2. QR Code Phishing (Quishing)

This method embeds malicious URLs directly inside QR code images placed inside document attachments. By doing this, the attacker forces the user to scan the code with their personal phone camera, shifting the attack away from the company's monitored desktop environment onto unmanaged, unlogged personal mobile web browsers.

3. Deepfake Live-Meeting & Voicemail Fraud

Threat actors are combining classic executive impersonation emails with generative AI voice clones or synthetic video. They send brief follow-up audio notes or join virtual meetings under stolen identities to explicitly order accounts payable teams to change invoice routing rules on the fly.